COMPTIA SECURITY+ SY0-701 | DOMAIN 4 · SECURITY OPERATIONS (28%)

Security+ 4.8 · Digital Forensics

Mestre CyberSec · **Lesson 4.8 — Digital Forensics** (9:54) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Forense: data collection (VOLÁTIL primeiro — RAM→cache→disco→backup); legal hold (preserva evidência — notifica o jurídico); chain of custody (quem tocou/ quando — sem isso a evidência não vale em tribunal).

💡 Key Exam Highlights & Critical Concepts

- Ordem de volatilidade: RAM primeiro (perde ao desligar)
- Chain of custody: o registro formal de cada ação com a evidência

🎯 Exam Tips & Typical CompTIA Scenarios

- 'documenting who handled the evidence'=chain of custody

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 4.8 — Digital Forensics)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Order of Volatility (OoV)

The required sequence for collecting digital evidence based on how quickly data degrades or disappears, starting with the most volatile source first.

⚠️ ***Exam Trap:*** *Lembre-se da ordem: RAM/CPU → cache/registradores → disco rígido → logs remotos → backups. Examinadores esperam a ordem RAM primeiro porque perde ao desligar.*

• Chain of Custody (N/A)

A formal, documented record of every person who handled a piece of digital evidence, the time it was transferred, and the actions taken at each step.

⚠️ ***Exam Trap:*** *Gatilho clássico: 'documenting who handled the evidence' = Chain of Custody. Sem ela, a evidência é inadmissível em tribunal.*

• Legal Hold (N/A)

A directive from legal counsel to preserve all relevant data and suspend routine destruction when litigation is reasonably anticipated.

⚠️ ***Exam Trap:*** *Legal Hold é emitida ANTES da coleta efetiva de evidência — notifica TI para parar de deletar dados (e-mails, logs). Não confundir com o processo de coleta em si.*

• Forensic Image (Bit-for-Bit Copy) (N/A)

An exact, sector-by-sector replica of a storage device, including deleted files and slack space, verified by cryptographic hash.

⚠️ ***Exam Trap:*** *NUNCA trabalhe diretamente no disco original — sempre crie uma imagem forense. Se o exame mencionar 'working with original evidence', é resposta errada.*

• eDiscovery

The process of identifying, collecting, and producing electronically stored information (ESI) in response to a legal request or investigation.

⚠️ ***Exam Trap:*** *eDiscovery é o processo corporativo/legal; Forensic é o técnico de campo. Legal Hold dispara o eDiscovery — pense em fluxo: Legal Hold → eDiscovery → Forensics.*

• **Data Acquisition (N/A)**
The process of extracting and preserving data from volatile (RAM) and non-volatile (disk) sources during a forensic investigation.

⚠️ ***Exam Trap:*** *Siga a ordem de volatilidade na prova: se a pergunta listar ações de aquisição, a ordem correta SEMPRE começa pela RAM.*

• **Integrity Verification (Cryptographic Hashing) (N/A)**
Using algorithms like MD5 or SHA-256 to generate a unique hash of evidence before and after acquisition to prove no tampering occurred.

⚠️ ***Exam Trap:*** *Hashes provam integridade — devem ser idênticos antes e depois. Se o hash mudar, a evidência foi comprometida. Use SHA-256 (não MD5) por padrão moderno.*

• **Right-to-Audit Clause (N/A)**
A contractual provision granting an organization the legal right to audit a third-party vendor's records and processes for compliance.

⚠️ ***Exam Trap:*** *Relacionado a evidências de terceiros: aparece em questões sobre fornecedores cloud/SaaS. Sem esta cláusula, você pode não ter acesso à evidência do provedor.*

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

An incident responder arrives at a compromised employee workstation that is still powered on and logged in. The responder needs to preserve the most volatile evidence before collecting the hard drive. Which action should the responder take first?

A) Remove the power cable to prevent encryption

B) Capture the contents of RAM using a forensic memory acquisition tool

C) Create a bit-for-bit image of the hard drive

D) Collect backup tapes from the data center

QUESTION 2 · EXAM SCENARIO

During a cybersecurity incident, the legal department informs the security team that litigation is reasonably anticipated. Which action best satisfies the need to preserve electronically stored information?

A) Enable automatic deletion of logs older than 30 days

B) Issue a legal hold notice and suspend routine destruction of relevant data

C) Move all affected systems to a public cloud

D) Allow users to continue normal file cleanup until a subpoena arrives

QUESTION 3 · EXAM SCENARIO

A forensic examiner receives a sealed evidence bag containing a malware-infected USB drive from a branch office. The examiner signs a receipt and later transfers the drive to a malware lab. What must be documented to maintain admissibility?

A) The chain of custody, including each person who handled the evidence and timestamps

B) The antivirus signature version used on the branch office endpoint

C) The network topology of the branch office

D) The user's browsing history from the last 24 hours

QUESTION 4 · EXAM SCENARIO

An investigator must acquire a forensic image from a suspect laptop. The laptop is powered off and the drive has not been altered. Which acquisition method best supports later courtroom use?

A) Booting the laptop and copying user files to an external drive

B) Using a write blocker and forensic imaging tool to create a bit-for-bit copy, then hashing the image

C) Taking screenshots of the file explorer and saving them as PDF

D) Running the operating system recovery tool to export documents

QUESTION 5 · EXAM SCENARIO

After creating a forensic image of a server's hard drive, the examiner calculates SHA-256 hashes of the original drive and the image. During trial, opposing counsel questions whether the image was modified. What is the primary purpose of these hashes?

A) To compress the image for long-term storage

B) To encrypt the image so unauthorized users cannot open it

C) To verify integrity and prove the image matches the original

D) To identify the malware family on the server

QUESTION 6 · EXAM SCENARIO

Legal counsel for a company receives a discovery request for all email related to a financial fraud allegation. The security team is asked to help. Which approach best aligns with eDiscovery and evidence preservation requirements?

A) Ask employees to delete irrelevant email before collection

B) Collect and preserve relevant electronically stored information under legal hold using defensible methods

C) Provide the requester with domain administrator credentials for direct mailbox access

D) Export only the CEO's mailbox because executives are most relevant

QUESTION 7 · EXAM SCENARIO

A company is negotiating a contract with a cloud service provider. The security team wants the contractual right to perform a forensic investigation if the provider suffers a breach affecting company data. Which contract clause should be requested?

A) Service level agreement (SLA)

B) Acceptable use policy (AUP)

C) Right-to-audit clause

D) Non-disclosure agreement (NDA)

QUESTION 8 · EXAM SCENARIO

A forensic analyst is preparing an acquisition plan for a running server that contains customer transactions. According to the order of volatility, which sequence should the analyst follow?

A) Hard disk, RAM, backup tapes, CPU cache

B) Backup tapes, hard disk, RAM, network connections

C) RAM, temporary file systems, hard disk, backup tapes

D) Network connections, backup tapes, hard disk, RAM

QUESTION 9 · EXAM SCENARIO

An employee's workstation is suspected in a data theft case. A technician collects the laptop and places it in the evidence locker but does not record the time of transfer or the receiving person's name. What is the most likely consequence?

A) The hash value of the disk will automatically change

B) The order of volatility will be reversed

C) The evidence may be challenged as not properly authenticated

D) The legal hold will convert into an eDiscovery request

QUESTION 10 · EXAM SCENARIO

A security analyst is asked to investigate a possible insider threat. Before starting, the analyst learns that the organization has received a notification from external counsel about anticipated litigation. What should the analyst do first?

A) Coordinate with legal counsel and ensure a legal hold is issued before collecting evidence

B) Begin imaging the laptop immediately and notify legal only if evidence is found

C) Suspend the employee's access and delete the suspect's mailbox to prevent data leakage

D) Wait for a subpoena before preserving any data

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option B — Capture the contents of RAM using a forensic memory acquisition tool
RAM is volatile and its contents are lost when the system loses power, so it must be collected before less volatile sources such as the disk or backups. Removing power destroys evidence, and imaging the disk first ignores the order of volatility.

Question 2: Option B — Issue a legal hold notice and suspend routine destruction of relevant data
A legal hold requires the organization to preserve potentially relevant evidence once litigation is anticipated. Suspending routine destruction and notifying custodians helps prevent spoliation and supports later eDiscovery.

Question 3: Option A — The chain of custody, including each person who handled the evidence and timestamps
Chain of custody documents who had control of the evidence, when, and for what purpose. Without an unbroken record, opposing counsel can challenge the authenticity and integrity of the evidence in court.

Question 4: Option B — Using a write blocker and forensic imaging tool to create a bit-for-bit copy, then hashing the image
A forensic image is a bit-for-bit copy of the storage media created with a write blocker to prevent modification. Hashing the original and the image helps demonstrate integrity and supports admissibility.

Question 5: Option C — To verify integrity and prove the image matches the original
Cryptographic hashes are used for integrity verification. If the hash of the original drive matches the hash of the forensic image, the examiner can show that the image has not been altered.

Question 6: Option B — Collect and preserve relevant electronically stored information under legal hold using defensible methods
eDiscovery requires identifying, preserving, collecting, and processing electronically stored information in a defensible manner. Deleting email or giving broad credentials would risk spoliation and unauthorized access.

Question 7: Option C — Right-to-audit clause
A right-to-audit clause gives the organization the contractual ability to audit or assess the provider's controls and, when needed, investigate security incidents. An SLA defines performance, an AUP defines user behavior, and an NDA protects confidential information.

Question 8: Option C — RAM, temporary file systems, hard disk, backup tapes
The order of volatility prioritizes the most volatile data first. RAM and temporary file systems can be lost quickly, while hard disks and backups are less volatile and can be collected later.

Question 9: Option C — The evidence may be challenged as not properly authenticated
Gaps in the chain of custody make it difficult to prove that the evidence was not altered or mishandled. Opposing counsel can challenge its authenticity, potentially weakening or excluding it from court.

Question 10: Option A — Coordinate with legal counsel and ensure a legal hold is issued before collecting evidence
When litigation is anticipated, a legal hold must be issued to preserve potentially relevant evidence. The forensic team should coordinate with legal counsel before collection so that evidence is preserved defensibly and not destroyed.